

Tugas Besar DevSecOps

Owner: Rangga & Azhar

Reviewer: Bapak Yuda

Contributors: rangga, azhar, ai, youtube, github

Date Generated: Tue Oct 06 2026

Executive Summary

High level system description

Sistem ini adalah subsistem Live Tracking untuk Web Komunitas Motor (Unknown Rider) yang dimigrasikan menggunakan arsitektur Laravel (PHP) sebagai backend dan MySQL sebagai database. Aplikasi beroperasi dengan mengandalkan komunikasi client-server melalui antarmuka REST API.

Alur kerja utama terdiri dari:

Client-Side (Frontend): Mengumpulkan data titik koordinat GPS pengguna (Latitude & Longitude) menggunakan HTML5 Geolocation API dan memvisualisasikannya di atas peta interaktif (Leaflet.js).

Data Ingestion (API POST): Klien mengirimkan titik koordinat ke sistem backend melalui endpoint /api/tracking/update untuk disimpan ke dalam tabel location_histories.

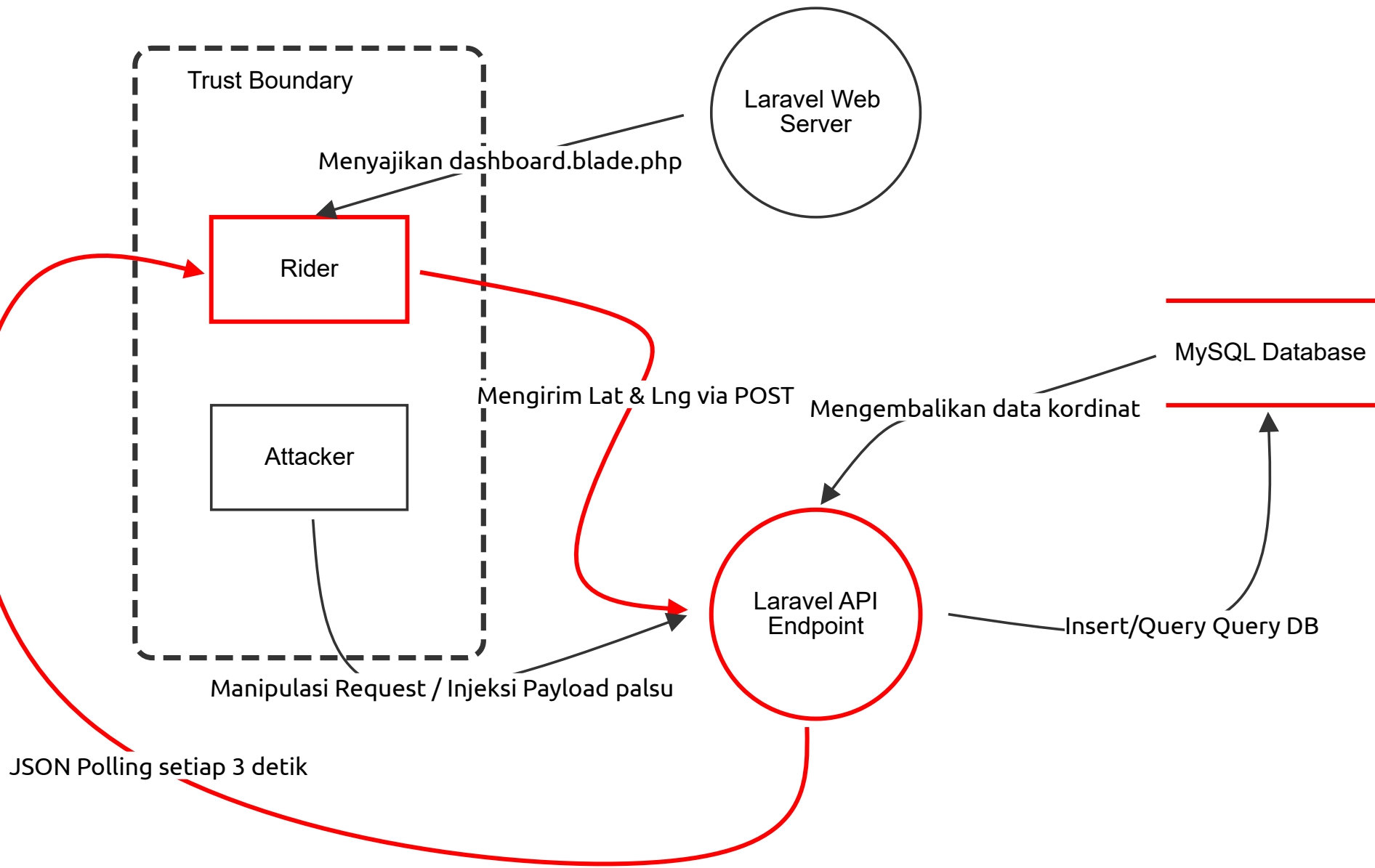
Data Retrieval (API GET / Polling): Klien secara otomatis menarik data koordinat terbaru dari seluruh anggota konvoi melalui endpoint /api/tracking/get menggunakan metode Polling setiap 3 detik.

Fokus Threat Model:
Pemodelan ancaman ini berfokus pada evaluasi keamanan endpoint API (potensi spoofing identitas rider dan manipulasi koordinat), potensi kebocoran data privasi lokasi akibat API yang terbuka tanpa otentikasi, serta kerentanan ketersediaan sistem (Denial of Service) akibat beban traffic dari metode polling.

Summary

Total Threats	6
Total Mitigated	0
Total Open	6
Open / Critical Severity	0
Open / High Severity	4
Open / Medium Severity	1
Open / Low Severity	1

New STRIDE diagram



New STRIDE diagram

Rider (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Spoofing Identitas Rider	Spoofing	High	Open		Hacker memalsukan pengiriman user_id untuk berpura-pura menjadi Road Captain atau anggota lain.	Gunakan otentikasi Laravel Sanctum. Ambil ID langsung dari sesi login backend (Auth::id()), jangan pernah memercayai user_id yang dikirim dari payload request frontend.

Attacker (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Laravel Web Server (Process)

Description: Menyajikan tampilan dashboard.blade.php							
--	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Laravel API Endpoint (Process)

Description: /api/tracking/update & /api/tracking/get							
---	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	DoS akibat Polling Masal	Denial of service	High	Open		Karena sistem menggunakan metode Polling (meminta data setiap 3 detik), jika ada ratusan rider yang membuka web bersamaan, server akan dibanjiri ribuan request terus-menerus yang berpotensi membuat database dan server crash (Self-DDoS).	Implementasikan Rate Limiting bawaan Laravel (Route::middleware('throttle:60,1')). Rencana jangka panjang: migrasikan arsitektur Polling menjadi WebSockets (contoh: Laravel Reverb/Pusher) untuk efisiensi koneksi real-time.
7	Peningkatan Hak Akses Illegal	Elevation of privilege	High	Open		Rider biasa (Sweeper atau anggota) memanipulasi celah di API untuk mengakses endpoint admin, misalnya mencoba menghapus riwayat lokasi atau mengubah rute konvoi yang bukan wewenangnya.	Terapkan Laravel Gates & Policies (Role-Based Access Control) di backend untuk memvalidasi apakah user yang melakukan request benar-benar memiliki peran (role) Admin atau Road Captain sebelum menjalankan aksi sensitif.

MySQL Database (Store)

Description: rockbikers_db / location_histories							
---	--	--	--	--	--	--	--

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Penyangkalan Jejak Lokasi	Repudiation	Low	Open		Anggota konvoi keluar jalur atau melanggar aturan konvoi, lalu menyangkal data lokasi di sistem dengan alasan "GPS-nya error", dan admin tidak punya bukti perangkat mana yang sebenarnya mengirim data.	ambahkan kolom ip_address dan user_agent pada tabel location_histories untuk merekam jejak perangkat secara permanen sebagai bukti audit (audit trail).

Mengirim Lat & Lng via POST (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Manipulasi Koordinat GPS	Tampering	Medium	Open		Attacker menggunakan alat seperti Burp Suite atau Inspect Element browser untuk mencegat dan mengubah angka latitude dan longitude menjadi lokasi palsu (misal: di tengah laut) sebelum sampai ke server.	Terapkan validasi input ketat di Controller (\$request->validate()). Tambahkan filter logis untuk menolak koordinat yang melompat terlalu jauh (di luar batas kecepatan kendaraan normal) dari posisi terakhir rider.

Insert/Query Query DB (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Mengembalikan data kordinat (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

JSON Polling setiap 3 detik (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Kebocoran Privasi Lokasi Konvoi	Information disclosure	High	Open		Endpoint /api/tracking/get dapat diakses secara publik. Pihak luar yang mengetahui URL tersebut dapat melacak lokasi seluruh anggota konvoi secara real-time tanpa perlu otentikasi.	Lindungi route API dengan Middleware Auth (Route::middleware('auth:sanctum')) agar data lokasi hanya bisa diambil oleh anggota yang sudah resmi login ke aplikasi.

Menyajikan dashboard.blade.php (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Manipulasi Request / Injeksi Payload palsu (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------